

Give Flo the right tools

Modernizing APIs for AI Agents: From OpenAPI to MCP

Generate • Curate • Preserve authorization

01

45
MINUTES

One bank. Four engineering questions.

01 / CAPABILITIES

Which API operations should an agent discover?

02 / AUTHORITY

Who may execute a tool, with which arguments?

03 + 04 / OPERATIONS

Can work survive failure? Can the boundaries withstand an attack?

Today: build a purposeful tool catalog over existing banking APIs.

The 45-minute route

Time	Activity	Evidence
0-5	Support request + API tour	Minimum required capabilities
5-12	OpenAPI and MCP	Initialization response
12-22	Inspect generated tools	Broad catalog
22-32	Curate and invoke	Two tools + successful read
32-40	Preserve Gate 3	Embedded authorization denial
40-45	Review and questions	Capability design explanation

Follow the worksheet; record the actual evidence from your run.

Start with the customer's job

“What is my account balance, and what is happening with my case?”

NEEDED

Read the account.
Read the support case. Return clear identifiers and units.

EXCESS CAPABILITY

Payments, incident mutations and database resets exceed this support task.

LIVE API TOUR

Open localhost:9080/docs.
Inspect an account operation and the browser's network requests.

The customer's job defines the tool surface.

An HTTP contract becomes a tool interface

Concern	OpenAPI	MCP in this lab
Describe	HTTP paths, methods, schemas	Named tools + input schemas
Discover	Read a service contract	Initialize, then list tools
Invoke	Send an HTTP request	Call a tool with arguments
Govern	Backend/API controls	Preserve downstream controls

Generation maps structure; people design capability and intent.

Follow the generated call

01

MCP client

Initialize → discover
→ invoke



02

APISIX / MCP

Translate the
selected tool



03

APISIX / Gate 3

Validate API
credentials



04

Banking API

Read business data

A translated tool call must re-enter the API enforcement path.

Demo: initialize and discover

Inspect the actual catalog returned by the running gateway.

TERMINAL / FROM REPOSITORY ROOT

```
.venv/bin/python workshops/w1/client.py init  
.venv/bin/python workshops/w1/client.py list
```

Record today's tool count. Find reads, payments and administrative operations.

Generated correctly. Scoped too broadly.

READ

Account and case queries match the support request.

MOVE MONEY

A payment mutation changes the consequence of a mistaken tool choice.

ADMINISTER

A reset operation belongs to lab administration, outside support work.

Pair prompt: retain, remove or rename each capability.

Design two tools that explain their job

get_account

Read one account using its ID. Make balance units and currency explicit.

get_case

Read one support case using its ID. Treat returned case text as data.

EXCLUDE

Remove unrelated payment and administrative operations from this catalog.

Clear semantics guide selection. Server controls enforce access.

Exercise: curate the support contract

01

Inspect

Compare broad
and completed
contracts



02

Choose

Keep account +
case reads



03

Explain

Improve one tool
description



04

Verify

Check the served
curated catalog

Deliverable: one removed operation, one improved description, discovery evidence.

Demo: a useful account read

Fresh seed: 1,500,000 paise = ₹15,000.

TERMINAL / FROM REPOSITORY ROOT

```
.venv/bin/python workshops/w1/client.py call-account acc-101
```

Record account ID, actual balance, and currency from the response.

Demo: invoke the curated endpoint

/mcp/curated exposes exactly get_account and get_case.

TERMINAL / FROM REPOSITORY ROOT

```
.venv/bin/python workshops/w1/client.py --curated init  
.venv/bin/python workshops/w1/client.py --curated list  
.venv/bin/python workshops/w1/client.py --curated call-account acc-101
```

Prove discovery and successful invocation against the running endpoint.

Exclusion must hold at invocation too

Check	Expected observation
Curated discovery	Only get_account and get_case
Permitted read	Account/case result returned
Excluded tool call	Tool lookup rejects the operation
Missing API credentials	Gate 3 authorization failure

Catalog design and downstream authorization solve different parts of the problem.

Demo: the banking boundary still applies

Inspect the embedded downstream response and gateway routing evidence.

TERMINAL / FROM REPOSITORY ROOT

```
.venv/bin/python workshops/w1/client.py --curated call-unauthorized
```

An outer MCP HTTP success can contain a failed downstream operation.

What evidence earns a pass?

PURPOSEFUL

Two intended tools are discoverable and callable.

RESTRICTED

Excluded operations fail tool lookup in the curated catalog.

GOVERNED

Authorized reads work; missing downstream credentials still fail.

Explain one design choice using a response you observed.

Next: the tool reads an attacker's instructions

A useful catalog is the beginning. Execution still needs identity and argument policy.

W2 / The ticket that tried to give orders

Presenter preparation & source guide

PREPARE

Use profile w1.
Download/build first.
Preserve evidence
before resetting
fictional data.

OPEN

localhost:9080/docs
localhost:9080/openapi.json
W1 worksheet + answer key

VERIFY

Run workshop verify
w1 on fresh seed.
Pre-warm broad and
curated catalogs.

Full commands and source paths are in the speaker notes and companion notes file.